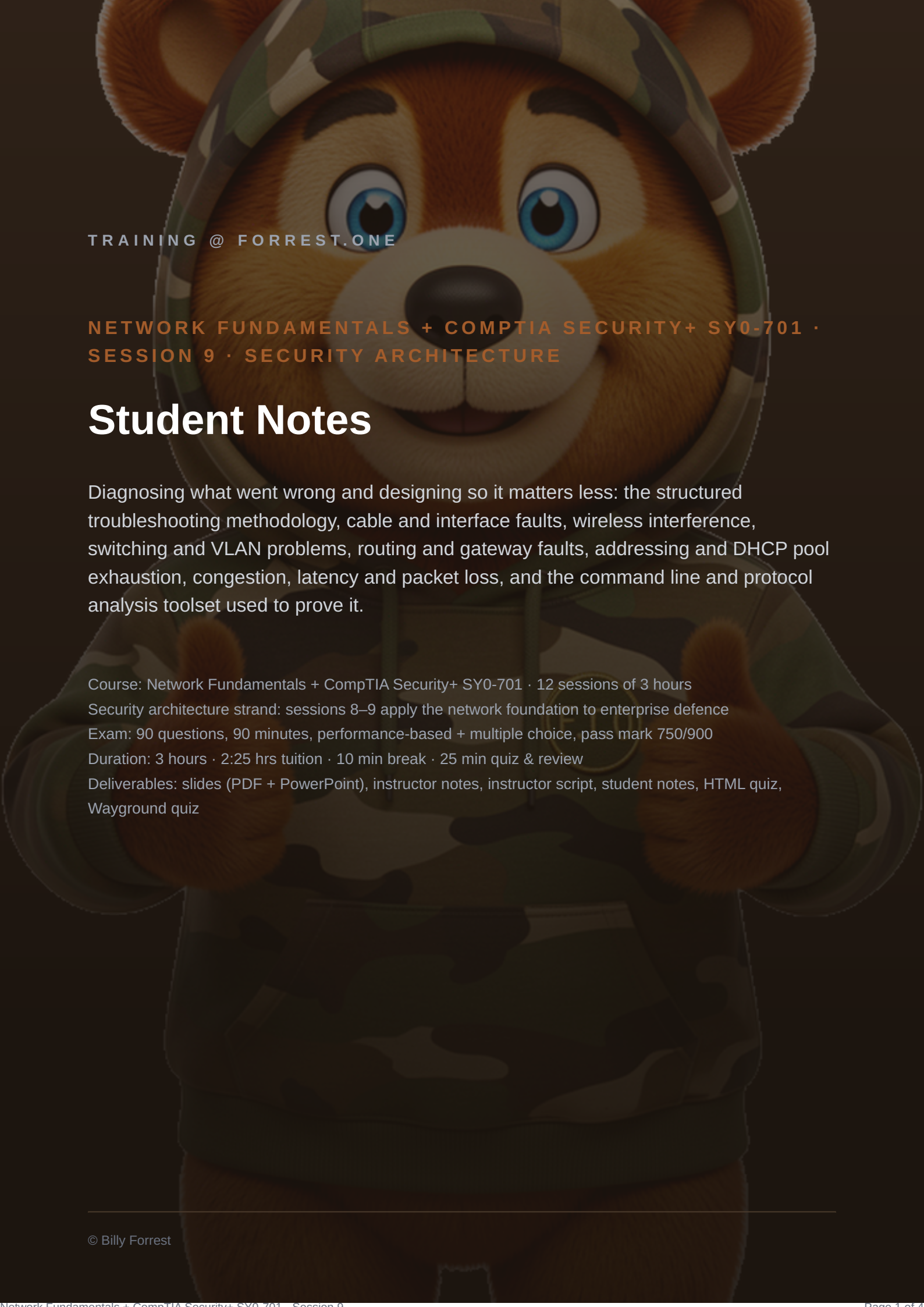




TRAINING @ FORREST.ONE

NETWORK FUNDAMENTALS + COMPTIA SECURITY+ SY0-701 ·
SESSION 9 · SECURITY ARCHITECTURE

Student Notes

Diagnosing what went wrong and designing so it matters less: the structured troubleshooting methodology, cable and interface faults, wireless interference, switching and VLAN problems, routing and gateway faults, addressing and DHCP pool exhaustion, congestion, latency and packet loss, and the command line and protocol analysis toolset used to prove it.

Course: Network Fundamentals + CompTIA Security+ SY0-701 · 12 sessions of 3 hours

Security architecture strand: sessions 8–9 apply the network foundation to enterprise defence

Exam: 90 questions, 90 minutes, performance-based + multiple choice, pass mark 750/900

Duration: 3 hours · 2:25 hrs tuition · 10 min break · 25 min quiz & review

Deliverables: slides (PDF + PowerPoint), instructor notes, instructor script, student notes, HTML quiz, Wayground quiz

Student Notes, Network Troubleshooting & Resilience

Your revision guide for Session 9. Read alongside the slides, then use the self-check questions and the session quiz to confirm you can pick the control for each asset class: endpoint, application, cloud.

Key terms

Term	Definition
EDR	Endpoint detection and response, behaviour-based monitoring
Allowlisting	Only pre-approved software runs, blocks unknown malware
Blocklisting	Known bad software is denied, misses unknowns
Code signing	Verifies software origin and integrity before execution
Secure baseline	A documented secure configuration from a known state
CIS benchmark	Consensus security configuration guidance from CIS
MDM	Mobile device management, enrol, configure, enforce, wipe
BYOD	Bring your own device, corporate data on personal devices
Application vetting	Assessing and approving apps before corporate install
Secure boot	Verified boot chain blocks tampered firmware
Firmware update	Patching below the operating system
Shift left	Security from the first design, not the last test
Threat modelling	Finding the attack surface before code exists
SAST / DAST	Source analysis / running-application testing
DevSecOps	Security in the CI/CD pipeline, not a release gate
Input validation	Whitelisting, sanitisation and boundary checks
SQL injection	User input treated as part of the query
XSS	Attacker script runs in another user's browser
CSRF	Forged request rides a victim's session
Sandboxing	Isolating code to contain any compromise

Term	Definition
Buffer overflow	Excess input overwrites memory
Directory traversal	Dot dot slash escapes the web root
IaaS / PaaS / SaaS	Infrastructure / platform / software as a service
Community cloud	Shared by organisations with common needs
Shared responsibility	Vendor secures the cloud; you secure what is in it
CASB	Cloud access security broker
Hypervisor	Type 1 bare metal or Type 2 hosted, separates the VMs
VM escape	Breaking out of the guest into the hypervisor host

Core concepts

9A, Endpoint security

The endpoint stack: AV/EDR (signature plus behaviour), hardening (baseline from CIS benchmarks or vendor guides, patching, disable unused services, ports and default accounts), application control (allowlisting over blocklisting, backed by code signing), MDM (enrol, configure, enforce, wipe) with application vetting and containers for BYOD, and OS controls, least privilege, secure boot, full disk encryption and firmware updates.

9B, Application lifecycle

Shift left: threat modelling before code, code review at every change, SAST for source and DAST for running apps. Secure coding keeps the code at least privilege, hides errors, and validates all input by whitelisting, sanitisation and boundary checks. DevSecOps puts security in the CI/CD pipeline and scans infrastructure as code, so secure code ships as fast as insecure code.

9C, Application attacks

SQL injection: input treated as code, fix with parameterised queries and input validation. XSS: script in another user's browser, fix with output encoding; a Web Application Firewall filters web traffic. CSRF: forged action on a session, fix with tokens and same-site cookies. Also buffer overflow, directory traversal and race conditions, mitigated by input validation, least privilege and sandboxing.

9D, Cloud & virtualisation

Service models: IaaS (you secure everything above the hypervisor), PaaS (you secure the app and its data), SaaS (the vendor secures nearly everything). Deployment models, public, private, hybrid and community, shift the line. Shared responsibility: vendor secures the cloud, you secure what is in it. Misconfiguration is the top cloud risk, managed with CASB and posture management. Virtualisation: the hypervisor is the crown jewel, Type 1 beats Type 2, VM escape is the nightmare, containers share the kernel and need namespaces and seccomp.

Practical cautions

- Do not rely on antivirus alone, signatures miss unknown threats.
- Do not choose blocklisting over allowlisting for unknown threats.
- Do not skip input validation, every field is a potential injection point.
- Do not confuse XSS (hijacks the browser) with CSRF (hijacks the action).
- Do not assume the cloud vendor secures your data and configuration.
- Do not assume private cloud has no shared responsibility, duties are still divided.
- Do not treat all hypervisors as equal, a Type 1 bare-metal hypervisor is safer than Type 2.
- Do not treat containers as perfectly isolated, they share the kernel.

Self-check questions

Answers are in your session slides

If you cannot answer a self-check from memory, revisit the corresponding slide, then retake the quiz.

Exam tips for Session 9

- Match the attack to the fix: injection to parameterised queries; XSS to output encoding; CSRF to tokens.
- The shared responsibility line is a favourite scenario, so know IaaS, PaaS, SaaS and the deployment models.
- Allowlisting versus blocklisting is a direct distinction; code signing verifies origin.
- Misconfiguration, not exotic attacks, is the number one cloud risk.
- Know the three data states, at rest, in transit and in use, and the control for each.
- Type 1 versus Type 2 hypervisor security is a recurring exam point.

Further reading

- OWASP Top 10, the application security risks catalogue.
- NIST SP 800-218, Secure Software Development Framework (SSDF).
- NIST SP 800-190, application container security guide.
- CIS Benchmarks, consensus security configuration guidance.
- CompTIA Security+ SY0-701 Exam Objectives, Domain 3 (Security Architecture).